

services\analysis\cwe\constants.py

```
"""
CWE Constants
Centralized constants and mappings for CWE analysis
"""
# Primary CWE titles mapping for core vulnerability weaknesses
# Maps CWE codes to human-readable descriptions for educational content
CWE_TITLES = {
"CWE79": "Cross-Site Scripting", # Web application XSS vulnerabilities
"CWE89": "SQL Injection", # Database injection attacks
"CWE20": "Improper Input Validation", # Input validation failures
"CWE22": "Path Traversal", # Directory traversal attacks
"CWE119": "Buffer Overflow", # Memory buffer overflow errors
"CWE200": "Information Exposure", # Unintended information disclosure
"CWE287": "Improper Authentication", # Authentication bypass vulnerabilities
"CWE120": "Buffer Copy without Checking Size", # Unchecked buffer operations
"CWE264": "Permissions, Privileges, and Access Controls", # Access control issues
"CWE193": "Off-by-one Error", # Array boundary errors
"CWE19": "Data Processing Errors", # General data handling issues
"CWE178": "Improper Handling of Case Sensitivity", # Case sensitivity bugs
"CWE17": "Code", # General code quality issues
"CWE276": "Incorrect Default Permissions", # Permission configuration errors
"CWE255": "Credentials Management", # Credential handling issues
"CWE327": "Use of a Broken or Risky Cryptographic Algorithm", # Weak cryptography
"CWE307": "Improper Restriction of Excessive Authentication Attempts", # Brute force
protection
"CWE384": "Session Fixation", # Session management vulnerabilities
"CWE88": "Argument Injection or Modification", # Command argument manipulation
"CWE78": "OS Command Injection", # Operating system command injection
"CWE59": "Improper Link Resolution Before File Access", # Symlink vulnerabilities
"CWE94": "Code Injection", # Dynamic code execution vulnerabilities
"CWE352": "Cross-Site Request Forgery", # CSRF attack vulnerabilities
"CWE434": "Unrestricted Upload", # File upload security issues
"CWE476": "NULL Pointer Dereference", # Memory access errors
"CWE862": "Missing Authorization", # Authorization bypass issues
"CWE74": "Improper Neutralization", # Input sanitization failures
"NVD-CWE-Other": "Other/Unclassified", # NVD catchall category
"NVD-CWE-noinfo": "Unclassified", # NVD unclassified vulnerabilities
"Unclassified": "Unknown" # Generic unknown classification
}

# Extended CWE titles including additional weaknesses for comprehensive analysis
# Merges base titles with specialized categories for advanced vulnerability analysis
EXTENDED_CWE_TITLES = {
**CWE_TITLES, # Include all base CWE titles
# Memory safety and buffer management weaknesses
"CWE125": "Out-of-bounds Read", # Memory read beyond boundaries
"CWE787": "Out-of-bounds Write", # Memory write beyond boundaries
"CWE416": "Use After Free", # Dangling pointer vulnerabilities
"CWE190": "Integer Overflow", # Numeric overflow conditions
"CWE191": "Integer Underflow", # Numeric underflow conditions
"CWE369": "Divide by Zero", # Division by zero errors
"CWE617": "Reachable Assertion", # Assertion failures in production
# Authentication and credential management
"CWE798": "Use of Hard-coded Credentials", # Embedded credentials in code
"CWE732": "Incorrect Permission Assignment", # File system permission errors
# Resource management and denial of service
"CWE770": "Allocation of Resources Without Limits", # Resource exhaustion
"CWE772": "Missing Release of Resource", # Resource leak vulnerabilities
"CWE775": "Missing Release of File Descriptor", # File descriptor leaks
"CWE401": "Missing Release of Memory", # Memory leak vulnerabilities
"CWE404": "Improper Resource Shutdown", # Resource cleanup failures
# Cryptographic and certificate management
"CWE295": "Improper Certificate Validation", # SSL/TLS certificate validation
"CWE326": "Inadequate Encryption Strength", # Weak encryption algorithms
"CWE347": "Improper Verification of Cryptographic Signature", # Signature validation
# Password and authentication strength
"CWE521": "Weak Password Requirements", # Insufficient password policies
"CWE522": "Insufficiently Protected Credentials", # Credential storage issues
"CWE916": "Use of Password Hash with Insufficient Computational Effort" # Weak hashing
}

# Severity weights for weighted CWE analysis and risk scoring
```

```

# Higher weights indicate higher priority for security response
SEVERITY_WEIGHTS = {
'CRITICAL': 4, # Highest priority - immediate action required
'HIGH': 3, # High priority - urgent remediation needed
'MEDIUM': 2, # Medium priority - timely remediation recommended
'LOW': 1, # Low priority - remediation as resources allow
'UNKNOWN': 1 # Unknown severity - treated as low priority for safety
}

# CWE categories for grouping related weaknesses by attack vector
# Supports categorical analysis and educational organization
CWE_CATEGORIES = {
# Injection attack vulnerabilities
'injection': ['CWE79', 'CWE89', 'CWE78', 'CWE94', 'CWE88'],
# Authentication and session management issues
'authentication': ['CWE287', 'CWE307', 'CWE384', 'CWE521', 'CWE522'],
# Authorization and access control problems
'authorization': ['CWE862', 'CWE264', 'CWE276', 'CWE732'],
# Input validation and sanitization failures
'validation': ['CWE20', 'CWE22', 'CWE178'],
# Buffer overflow and memory safety issues
'buffer_errors': ['CWE119', 'CWE120', 'CWE125', 'CWE787'],
# Memory management and resource handling
'memory_management': ['CWE416', 'CWE401', 'CWE770', 'CWE772'],
# Cryptographic implementation weaknesses
'cryptographic': ['CWE327', 'CWE295', 'CWE326', 'CWE347'],
# Information disclosure vulnerabilities
'information_exposure': ['CWE200', 'CWE255', 'CWE798'],
# Resource management and denial of service
'resource_management': ['CWE404', 'CWE775', 'CWE369']
}

# Top 25 most dangerous CWEs based on OWASP/CWE research
# Industry-standard prioritization for vulnerability assessment and education
TOP_25_CWES = [
'CWE787', # Out-of-bounds Write
'CWE79', # Cross-site Scripting
'CWE125', # Out-of-bounds Read
'CWE20', # Improper Input Validation
'CWE78', # OS Command Injection
'CWE89', # SQL Injection
'CWE416', # Use After Free
'CWE22', # Path Traversal
'CWE352', # Cross-Site Request Forgery
'CWE434', # Unrestricted Upload of File with Dangerous Type
'CWE476', # NULL Pointer Dereference
'CWE287', # Improper Authentication
'CWE190', # Integer Overflow or Wraparound
'CWE502', # Deserialization of Untrusted Data
'CWE77', # Command Injection
'CWE119', # Improper Restriction of Operations within Buffer
'CWE798', # Use of Hard-coded Credentials
'CWE862', # Missing Authorization
'CWE276', # Incorrect Default Permissions
'CWE200', # Information Exposure
'CWE522', # Insufficiently Protected Credentials
'CWE732', # Incorrect Permission Assignment for Critical Resource
'CWE611', # Improper Restriction of XML External Entity Reference
'CWE918', # Server-Side Request Forgery (SSRF)
'CWE77' # Command Injection (duplicate in original - maintaining for compatibility)
]

```